

Mobile NFC-Zahlungen

Sicherheitsanalyse kontaktloser Zahlungssysteme

Hiebert, Andreas
Hochschule Hamm-Lippstadt

EINLEITUNG / MOTIVATION

Kontaktloses Bezahlen per NFC (Near Field Communication) hat sich in den letzten Jahren zum Standard im Zahlungsverkehr entwickelt. Ob physische Bankkarte oder Smartphone mit Apple Pay und Google Pay: Millionen Transaktionen werden täglich über die 13,56-Mhz-NFC Schnittstelle abgewickelt.

Doch wie sicher ist diese Technologie wirklich? Welche Daten werden bei einer kontaktlosen Zahlung übertragen, und welche davon könnte ein Angreifer abfangen und verwerten? Diese Fragen sind für die IT-Sicherheit von zentraler Bedeutung.

Ziel dieses Projekts ist es, die Sicherheitsarchitektur kontaktloser NFC-Zahlungen zu analysieren und die Unterschiede zwischen physischen Karten und tokenisierten mobilen Zahlungen durch praktische Laborexperimente mit einem NFC-Sniffer zu veranschaulichen.

METHODIK UND MATERIAL

Hardware und Software für die Laborexperimente:

- Proxmark3 Easy (Iceman-Firmware) als NFC-Sniffer
- ThinkPad X230 mit Linux Mint als Analyse-Plattform
- REINER SCT cyberJack RFID Komfort als Zweit-Leser
- Google Pixel 9 mit Google Pay (HCE-Testzahlungen)
- Revolut Visa-Karte als physische Testkarte
- NTAG215 NFC-Tags und MIFARE Classic Magic Cards

Methode: Aufzeichnung der ISO-14443-Kommunikation im Sniff-Modus des Proxmark3. Vergleichende Analyse der APDU-Sequenzen (SELECT PPSE, GPO, READ RECORD, GENERATE AC) bei physischer Kartenzahlung und Google-Pay-Zahlung am selben Terminal.

ERGEBNIS

Die Analyse der aufgezeichneten NFC-Traces zeigt deutliche Sicherheitsunterschiede zwischen den Zahlungsmethoden:

Physische Karte: Die echte Kartenummer (PAN) und das Ablaufdatum werden im Klartext über die NFC-Schnittstelle übertragen. Im Trace sind zusätzlich die statische UID, die Issuer-Zertifikate und der Kartentyp (AID) sichtbar. Diese Daten könnten theoretisch für Card-Not-Present-Betrug missbraucht werden.

Google Pay (HCE): Anstelle der echten PAN wird nur ein gerätegebundener Token (DPAN) übertragen. Die UID ändert sich bei jeder Sitzung zufällig. Es werden keine Issuer-Zertifikate oder Chip-Identifikationen preisgegeben. Das Terminal muss sich zudem stärker validieren, bevor die Zahlungsanwendung Daten freigibt.

Fazit der Analyse: Google Pay ist in jeder Hinsicht datenschutzfreundlicher. Tokenisierung, zufällige UID und erzwungene biometrische Authentifizierung eliminieren die Hauptangriffsflächen physischer Karten vollständig.

Der Proxmark 3 Easy zeichnet die NFC-Kommunikation zwischen Karte und Terminal passiv auf, ohne die Transaktion zu stören. Die Traces werden anschließend auf APDU-Ebene analysiert.



Abb.2:
Proxmark3 Easy NFC-Sniffer



Abb.1:
Kontaktloses Bezahlen wird immer beliebter



Abb.2:
Meistgenutzte Bezahl Apps in 2024

FAZIT

Die praktische Untersuchung bestätigt die theoretische Analyse: Tokenisierte mobile Zahlungen (Apple Pay, Google Pay) bieten ein deutlich höheres Sicherheitsniveau als physische kontaktlose Karten.

Der entscheidende Unterschied liegt in drei Faktoren: (1) Tokenisierung ersetzt die echte Kartenummer durch einen wertlosen, gerätegebundenen Token. (2) Erzwungene biometrische Authentifizierung (CDCVM) verhindert unautorisierte Nutzung. (3) Zufällige UIDs pro Sitzung verhindern Tracking.

Replay-Angriffe scheitern bei allen Methoden am dynamischen Kryptogramm und dem Transaktionszähler (ATC). Die größte verbleibende Angriffsfläche ist die Klartext-PAN physischer Karten, die bei mobilen Zahlungen vollständig eliminiert wird.

REFERENZEN

- [1] EMVCo: EMV Contactless Specifications for Payment Systems, Books A-D. emvco.com
 - [2] ISO/IEC 14443: Contactless integrated circuit cards - Proximity cards, Parts 1-4.
 - [3] EMVCo: EMV Payment Tokenisation Specification - Technical Framework, v2.x.
 - [4] Postbank Digitalstudie 2024: Schon zwei Drittel der Deutschen zahlen im Vorbeigehen
- Weitere Quellen auf Nachfrage